



17 April 2026

WEB APPLICATION PENETRATION TESTING REPORT

Prepared For:

TODO: fill field in report

Prepared By:

IARM Information Security

Table of Contents

1.0 Document Control	3
2.0 About Us	4
3.0 Engagement Summary	5
3.1 Project Overview	5
3.2 Goals	5
3.3 Approach	5
3.4 Framework	6
3.5 Technical Summary	6
3.5.1 Reassessment Guidelines	6
3.5.2 Out of Scope	6
3.5.3 Post Assessment Clean-up	7
3.5.4 Severity Rating Scale	7
3.5.5 Ease of Exploit Scale	7
4.0 Findings Dashboard	8
5.0 Findings Summary	9
6.0 Assessment Report	10
7.0 Conclusion	14
8.0 Appendix	14
8.1 Disclaimer	14
8.2 Checklist Overview	14

IARM

1.0 Document Control

Client Confidentiality

This document contains **Client Confidential information** and may not be copied without written permission.

Proprietary Information

The content of this document is considered **proprietary information** and should not be disclosed outside of the recipient organization's network.

IARM Pentest Team gives permission to copy this report for the purposes of disseminating information within your organization or any regulatory agency.

Document Version Control

Issue No	Issue Date	Issued By	Change Description
0.1	17-04-2026	Anish R	Basic Document Outline
0.2	17-04-2026	Anish R	Draft Document
0.3	17-04-2026	Vignesh C	Peer Review
1.0	17-04-2026	Vignesh C	Released to Client

Project Metadata

Field	Details
Client Name	TODO: fill field in report
Application Name	TODO: fill field in report
Application Version	TODO: fill field in report
Document Title	TODO: fill field in reportWeb Application Penetration Testing Report
Date of Version	17-04-2026
Created By	Anish R
Approved By	Thanikainathan TS (ISMS Lead Auditor)
Confidentiality Level	Very High

2.0 About Us



IARM is a distinguished cyber security organization that provides an extensive array of cyber security assessment capabilities and services tailored to meet each client's specific needs. Whether it's developing a comprehensive cyber security strategy or implementing tailored solutions that align with an organization's size and requirements, IARM possesses the expertise, skills, and experience necessary to safeguard against potential threats and vulnerabilities effectively.

IARM holds **CREST accreditation** for penetration testing services, a prestigious recognition of our steadfast dedication to delivering the highest levels of security testing and consulting services. CREST is a globally respected authority known for its rigorous certification standards, and we are proud to have not only met but surpassed these stringent benchmarks.

Country: USA | India | Singapore

Website: <https://www.iarminfo.com>

Email: info@iarminfo.com

US: +1 5512422980 | **India:** 18001021532

IARM

3.0 Engagement Summary

3.1 Project Overview

The organization **TODO: fill field in report** enlisted **IARM Information Security** for a security assessment **Web Application Penetration Test** against their in-house developed **TODO: fill field in report** application. This report comprehensively outlines the vulnerabilities identified throughout the engagement, which commenced on **17-04-2026**.

Scope Centre

Scope Details	
Name	TODO: fill field in report
Version	TODO: fill field in report
Approach	Grey Box
URL	corporis reprehenderit inventore enim

3.2 Goals

- **Identify and assess vulnerabilities:** Conduct a thorough examination of the web application to uncover potential security weaknesses.
- **Exploit and validate findings:** Actively exploit vulnerabilities to validate their existence and assess the severity of potential security threats.
- **Provide recommendations for mitigation:** Offer actionable recommendations to address identified vulnerabilities and enhance overall web application security.
- **Ensure compliance and resilience:** Verify that the web application complies with security standards and regulations, while building resilience against potential cyber threats.

3.3 Approach

The assessment team conducted a comprehensive **Penetration Test**, leveraging real-world attack techniques to evaluate the security posture of the application. The engagement began with automated scans of the deployed application, followed by meticulous analysis of the results. Automated findings were combined with manual reviews to ensure a thorough identification of potential security vulnerabilities.

In addition, the team performed a detailed assessment of the application architecture and business logic to identify potential design-level weaknesses that could compromise security. This approach ensured that both technical and logical vulnerabilities were examined comprehensively.

To validate the findings, manual exploitation techniques were employed wherever appropriate. The application was assessed within a live environment in accordance with industry best practices and recognized testing frameworks. The team utilized both open-source and commercial tools including **Nessus Professional**, **Kali Linux**, **Postman**, **Nmap Scripts**, and **Burp Suite Professional**. Manual testing was conducted extensively to ensure a complete and in-depth evaluation of the application's security posture.

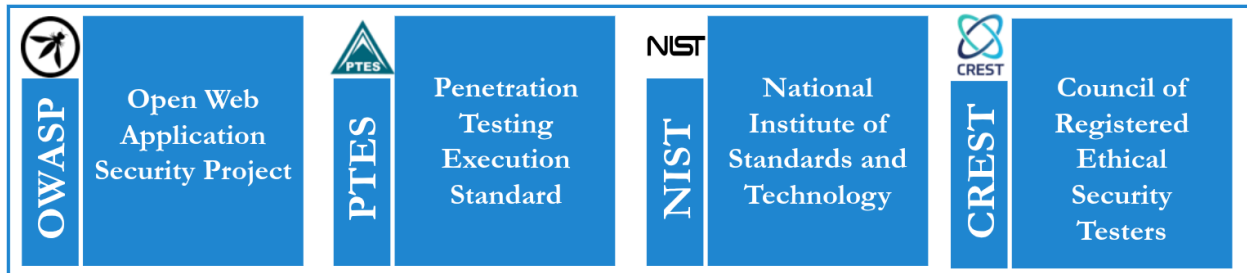
- Perform broad scans to identify potential areas of exposure and services that may act as entry points.
- Perform targeted scans to identify specific vulnerabilities.
- Conduct supplemental research and development activities to support detailed analysis.

- Identify issues of immediate consequence and recommend remediation actions.
- Develop long-term strategic recommendations to enhance overall security resilience.

3.4 Framework

IARM Information Security's penetration testing methodology is aligned with recognized industry standards and best practices. The assessment approach is structured to ensure comprehensive coverage, consistency, and adherence to globally accepted security testing frameworks.

The methodology is based on the following industry standards:



3.5 Technical Summary

Planner Board	
Project ID	IARM-
Time Frame	From 17-04-2026 To 17-04-2026
Engagement Type	Grey Box
Report date	2026-04-17

3.5.1 Reassessment Guidelines

A one-time retest is optional. The retest shall be performed on all identified vulnerabilities as a single consolidated exercise. The customer must confirm the completion of remediation for all identified vulnerabilities as part of the initial engagement in order to avail of the optional retest.

Any retest not conducted within **60** from the date of submission of the initial assessment report will be considered a **"Fresh Audit"**, for which additional commercial terms shall be provided upon request.

3.5.2 Out of Scope

- error beatae
- expedita veritatis
- Fixing or remediation of identified vulnerabilities is not part of this engagement.
- Post-incident analysis and log review assessments are not included in the scope.
- A complete network configuration review is not part of the audit scope.
- Other web services running on different ports, except those associated with the scoped application, are excluded.
- Third-party services and microservices are not part of this assessment.
- AWS/Azure cloud security assessments (cloud infrastructure review) are not included in the penetration test scope.

3.5.3 Post Assessment Clean-up

Any test accounts created specifically for the purpose of this assessment should be disabled or removed, as appropriate, along with any associated data or content generated during testing activities.

3.5.4 Severity Rating Scale

The assessment team used defined criteria to evaluate and rate the findings identified during the engagement. Risk ratings are derived from the calculated IARM risk scoring methodology, which considers impact, exploitability, exposure, and overall business risk.

CRITICAL	System-level compromise can be readily achieved through exploitation of this vulnerability, posing a critical risk to the entire environment. Immediate remediation, including urgent patching and proactive mitigation measures, is strongly needed to prevent potential full system takeover and further impact.
HIGH	Exploitation of this vulnerability may present certain challenges; however, it still carries a considerable risk of enabling elevated privileges, potentially resulting in data loss or system disruption. It is strongly recommended to promptly implement a remediation plan and apply the necessary patches without delay to mitigate potential impact.
MEDIUM	The identified vulnerabilities present a moderate risk, as exploitation may be constrained or require more conditions such as user interaction or social engineering. A structured remediation plan should be developed to address these issues in a prioritized and prompt manner.
LOW	The identified vulnerabilities currently present a minimal risk, as they are not readily exploitable; however, they may contribute to a reduced security posture over time. It is recommended to define a remediation plan and address these issues during the next scheduled maintenance window to support a proactive security stance.
INFO	The identified findings do not pose an immediate threat; however, they may show information that could be useful to potential attackers. While these issues do not directly affect the confidentiality, integrity, or availability of the system, they may contribute to increased risk when combined with other vulnerabilities.

3.5.5 Ease of Exploit Scale

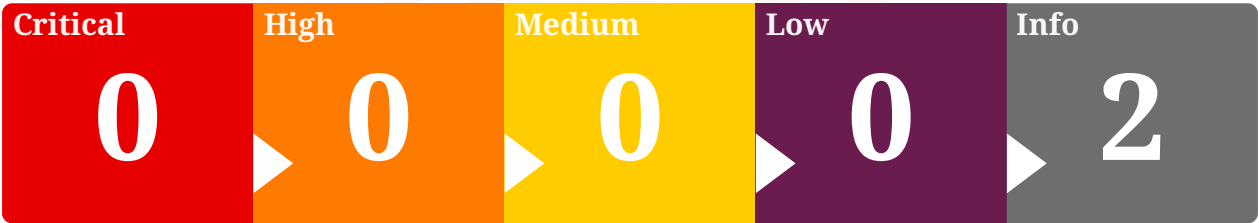
Difficult	Determined	Exploitation is complex and requires advanced skills, significant effort, or multiple dependencies and unlikely conditions.
Moderate	Technocrat	Exploitation requires certain conditions, some level of technical ability, or limited user interaction to be successful.
Trivial	Normal User	Exploitation can be performed with minimal effort, requiring little to no specialized knowledge, tools, or preconditions.

4.0 Findings Dashboard

For each identified finding, IARM Information Security applies a structured **IARM Risk Score** methodology. This risk score evaluates multiple factors including the severity of the vulnerability, application exposure, user population impact, technical complexity of exploitation, and overall business risk.

The objective of this scoring model is to provide a clear and consistent understanding of the risk posture associated with each vulnerability. For a detailed explanation of the IARM risk rating methodology and vulnerability categorization, please refer to the **Risk Rating Scale (Section 3.5.4)**.

Vulnerability	Criticality
First Demo Finding	Info
Second Demo Finding	Info



IARM

5.0 Findings Summary

First Demo Finding

TODO: High-level summary

Second Demo Finding

TODO: High-level summary



6.0 Assessment Report

The vulnerabilities below were identified and verified by IARM Information Security during the process of this Penetration Testing.

6.1 First Demo Finding

Risk Level	Ease of Exploit	CWE
Info	Difficult	CWE-

Description

TODO: detailed technical description what this findings is about and how it can be exploited

CVSS Score:

0.0 - n/a

Business Impact

TODO: impact of finding

Affected Components

- TODO: affected component
- TODO: affected component

Payload

- `magnam ducimus`
- `officia quisquam`

Proof of Concept

Lorem ipsum dolor sit amet, consectetur adipisicing elit, sed do eiusmod tempor incididunt ut labore et dolore magna aliqua. Ut enim ad minim veniam, quis nostrud exercitation ullamco laboris nisi ut aliquip ex ea commodo consequat. Duis aute irure dolor in reprehenderit in voluptate velit esse cillum dolore eu fugiat nulla pariatur. Excepteur sint occaecat cupidatat non proident, sunt in culpa qui officia deserunt mollit anim id est laborum. Placeat aliquid temporibus nemo distinctio a itaque dolorem libero provident magnam, architecto modi voluptate rem laboriosam hic dignissimos eaque animi, totam quae eius animi et deserunt porro cupiditate, sint non fuga iste quis temporibus dolores ab atque blanditiis, error amet nihil iusto reprehenderit repellat cum dolorem adipisci suscipit commodi. Cum autem aperiam voluptate, sed expedita repellendus? Eligendi repellendus ipsa nobis eveniet corporis labore voluptate, rerum facere itaque amet eos fuga odio quidem assumenda tenetur, earum voluptate quod beatae id consequuntur atque aut illum, animi nostrum facere fugit sit dignissimos maxime ratione laboriosam corrupti fuga. Tenetur nostrum obcaecati velit ipsum et modi facere explicabo, suscipit ducimus accusamus inventore aut quisquam veritatis minima quas neque nulla, architecto quia ullam nam vitae, dolorem autem error soluta. Quod libero repellat dignissimos vero, delectus minima optio facilis, aperiam laudantium a ad maiores magnam eligendi rem consequuntur. Id quidem reiciendis, blanditiis veniam maxime recusandae rerum sit rem illo at qui, inventore hic beatae dicta rem debitis ad mollitia aspernatur quis, vel ipsum necessitatibus vero placeat odio minus eos maiores. Ex reprehenderit quo debitis sequi ratione est ea, tempore consequuntur doloremque ea distinctio eaque, quo quasi commodi, aspernatur consequuntur voluptatum aliquam accusamus optio, molestias magni rerum fugit debitis mollitia dolores id?

Recommendation

TODO: how to fix the vulnerability

References

- officia quo
- nisi assumenda



6.2 Second Demo Finding

Risk Level	Ease of Exploit	CWE
Info	Difficult	CWE-

Description

TODO: detailed technical description what this findings is about and how it can be exploited

CVSS Score:

0.0 - n/a

Business Impact

TODO: impact of finding

Affected Components

- TODO: affected component
- TODO: affected component

Payload

- hic culpa
- earum non

Proof of Concept

Lorem ipsum dolor sit amet, consectetur adipisicing elit, sed do eiusmod tempor incididunt ut labore et dolore magna aliqua. Ut enim ad minim veniam, quis nostrud exercitation ullamco laboris nisi ut aliquip ex ea commodo consequat. Duis aute irure dolor in reprehenderit in voluptate velit esse cillum dolore eu fugiat nulla pariatur. Excepteur sint occaecat cupidatat non proident, sunt in culpa qui officia deserunt mollit anim id est laborum. Vitae eveniet laboriosam, amet similique laudantium labore numquam. Veritatis dolor magnam quod labore, incidunt molestiae atque assumenda sequi officiis in, quisquam similique facere facilis ducimus quas laboriosam. Reprehenderit molestiae laudantium neque, odio ipsa voluptatem optio adipisci dolorem natus architecto delectus officia eos facilis, ducimus eaque inventore hic iusto quo sed exercitationem molestias accusantium facilis soluta. Vero itaque perferendis pariatur sunt facilis reprehenderit consectetur ea, ipsa iure illum hic sapiente voluptate magnam obcaecati voluptas temporibus in, voluptates doloremque modi minima ipsam, alias eos nisi dicta, id autem fuga vel laudantium ab expedita sunt animi delectus. Ab perspiciatis nihil ea obcaecati fugiat ipsa, consequatur quaerat ex asperiores aspernatur eius possimus ea est voluptates, alias doloremque soluta, aliquam earum dolores. Provident odit sunt facilis ipsam praesentium deleniti possimus perferendis dignissimos, eos quidem delectus beatae obcaecati officia asperiores, dignissimos similique aliquam itaque et cupiditate, iusto vitae molestias asperiores sint voluptate nemo, accusamus odit vero laboriosam obcaecati consectetur delectus. Consequuntur voluptate impedit sapiente cum modi nam officiis delectus, impedit voluptas animi iste officiis quaerat dolore reprehenderit eveniet, eos eius saepe repellat est consequuntur.

Recommendation

TODO: how to fix the vulnerability

References

- repudiandae incidunt
- ducimus eveniet



7.0 Conclusion

As per the defined scope, the **Web Application Penetration Testing** for the application has been successfully completed. During the assessment identified vulnerabilities were need to be remediated at the earliest to avoid the risk of potential malicious exploitation.

Information Security Assessment is not a one-time activity but a continuous practice essential to maintaining the overall security posture and hygiene of the application. Regular security evaluations help proactively identify emerging threats and newly introduced vulnerabilities.

It is strongly recommended to conduct **security assessments on a quarterly basis** to ensure ongoing protection, compliance, and resilience against evolving cyber threats.

8.0 Appendix

8.1 Disclaimer

The Penetration Testing was conducted by IARM Information Security Pvt Ltd using Open source and Commercial of the shelf tools wherever applicable as per the defined and agreed scope of work. No further analysis or interpretation was carried out on the outcome of the report generated from the tools used. Information security threats are continually changing, with new vulnerabilities discovered on a daily basis. Limited testing or one time testing without manual testing or interpretation without Business logic may not provide accurate results in the report. and no application can ever be 100% secure no matter how much security testing is conducted. The service provider shall take all reasonable steps to provide accurate and comprehensive test results within the agreed scope of the services but cannot be held liable if the testing undertaken fails to discover certain security vulnerabilities or configuration issues on the systems under test.

8.2 Checklist Overview

OWASP Web Security Top 10 (2025)

- A01:2025 – Broken Access Control
- A02:2025 – Security Misconfiguration
- A03:2025 – Software Supply Chain Failures
- A04:2025 – Cryptographic Failures
- A05:2025 – Injection
- A06:2025 – Insecure Design
- A07:2025 – Authentication Failures
- A08:2025 – Software or Data Integrity Failures
- A09:2025 – Security Logging & Alerting Failures
- A10:2025 – Mishandling of Exceptional Conditions

OWASP API Security Top 10 (2023)

- API1:2023 – Broken Object Level Authorization (BOLA)
- API2:2023 – Broken Authentication
- API3:2023 – Broken Object Property Level Authorization (BOPLA)
- API4:2023 – Unrestricted Resource Consumption
- API5:2023 – Broken Function Level Authorization
- API6:2023 – Unrestricted Access to Sensitive Business Flows

API7:2023 – Server Side Request Forgery (SSRF)

API8:2023 – Security Misconfiguration

API9:2023 – Improper Inventory Management

API10:2023 – Unsafe Consumption of APIs

IARM High-Level Test Cases

Recon & Mapping

- Subdomain enumeration
- Hidden and staging environment discovery
- Technology stack fingerprinting
- JavaScript file enumeration and parameter discovery
- API endpoint enumeration
- Framework and plugin version identification
- Cloud storage and bucket discovery
- Third-party service discovery
- Public repository leak checks
- OpenAPI / Swagger / GraphQL schema discovery
- CDN and edge worker enumeration
- Mobile API endpoint mapping

Authentication

- Weak password policy validation
- Brute-force and rate-limit testing
- Account lockout validation
- Multi-factor authentication implementation review
- MFA bypass attempts
- Password reset token security validation
- Account recovery workflow testing
- Username and email enumeration checks
- Session fixation testing
- JWT signing and token validation
- Long-lived authentication token analysis
- Token revocation validation
- Single Sign-On (OAuth/SAML/OIDC) misconfiguration testing
- Social login flow validation
- Re-authentication enforcement for sensitive actions

Session Management

- Predictable session identifier testing
- Session invalidation on logout
- Session timeout and inactivity expiration
- Secure cookie flags validation (Secure, HttpOnly, SameSite)
- Session token leakage via URLs
- Reuse of old session tokens
- Session takeover attempts via CSRF and token manipulation

Authorization

- IDOR / BOLA testing
- Broken function-level authorization checks
- Object property authorization validation
- Vertical privilege escalation testing
- Horizontal privilege escalation testing
- User-to-user data isolation validation
- Hidden parameter abuse enabling administrative functions
- HTTP method tampering for authorization bypass
- Role-based access control misconfiguration checks
- Multi-tenant boundary validation

API Security

- API rate limiting validation
- API key strength and enforcement checks
- API key leakage detection
- HTTP verb tampering
- GraphQL introspection exposure
- GraphQL deep query abuse
- GraphQL field-level authorization bypass
- Pagination abuse checks
- Bulk operation abuse
- Mass assignment vulnerabilities
- Unsafe deserialization in APIs
- API parameter pollution
- Business logic vulnerabilities in APIs
- Overly permissive CORS configuration
- API response caching of sensitive data
- HTTP header manipulation testing
- Mobile API endpoint abuse

Input Validation & Injection

- SQL Injection testing (classic, blind, error-based, time-based)
- Out-of-band SQL injection validation
- SQL injection in headers, cookies and JSON parameters
- NoSQL injection testing
- Array and object-based NoSQL injection
- Command injection testing
- Chained command injection attempts
- Blind OS command execution testing
- Server-Side Template Injection (SSTI)
- Template engine context injection
- LDAP injection testing
- Expression language injection
- XML External Entity (XXE) attacks
- XSLT injection testing

Cross-Site Scripting (XSS)

- Reflected XSS testing
- Stored XSS testing
- DOM-based XSS testing
- Framework-specific XSS vulnerabilities
- Template-based XSS testing
- Prototype pollution leading to XSS
- SVG, JSON and POST based XSS payload testing
- Sanitization and WAF bypass attempts
- CORS induced XSS vectors

CSRF & State Management

- Cross-Site Request Forgery testing on sensitive actions
- Missing CSRF token validation
- Predictable anti-CSRF token detection
- CORS misconfiguration enabling CSRF
- Cookie misconfiguration enabling CSRF attacks

Business Logic

- Price manipulation testing
- Quantity manipulation checks
- Coupon abuse scenarios
- Workflow and ordering manipulation
- Race condition exploitation
- Double-spend scenarios
- Payment flow tampering
- Mandatory step bypass attempts
- Improper state transitions
- Workflow skipping validation
- Rate-limit abuse scenarios
- Inventory manipulation testing
- Privileged workflow sequencing flaws

File Upload Security

- Executable file upload attempts
- MIME type spoofing
- Polyglot file upload testing
- SVG and XXE payload uploads
- Filename manipulation
- Upload to public storage buckets
- Image upload leading to SSRF
- Webshell upload attempts
- Antivirus and scanning bypass

Server-Side Request Forgery (SSRF)

- External SSRF testing
- Internal SSRF testing
- Cloud metadata service access attempts
- DNS rebinding techniques
- URL parser bypass attempts
- Protocol smuggling
- Image fetch SSRF vectors
- Webhook SSRF abuse
- Blind SSRF detection

Cloud & Infrastructure

- Public cloud bucket exposure
- Misconfigured object permissions
- Cloud metadata exposure
- IAM privilege escalation checks
- CI/CD token leakage
- Environment variable leakage
- Hardcoded cloud credentials
- Container breakout risks
- Exposed Docker APIs
- Kubernetes API exposure
- Over-permissive Kubernetes RBAC
- Secrets in container layers

Data Protection

- Exposure of personally identifiable information (PII)
- Sensitive data exposure in logs
- Sensitive data leakage in URLs
- Improper caching of private data
- Accessible backup files
- Data export endpoint exposure